

TETZ2026 Vibe Coding Kampı · EKİP 12

Güvenlik — Form & XSS Testleri

Bu rehberi sırayla takip et.

● XSS testi yaparken sadece test ortamında çalış. Zararlı kod enjekte etmeye çalışmak değil, sistemin savunmasını test etmek amaçlı.

i Bu rehberde 5 bölüm var: (A) Hazırlık (B) Projeyi indir (C) Görevin (D) Testleri yap (E) Gönder.

A. Hazırlık

1 Git'i kur

git-scm.com/downloads → kur

2 Git'e adını tanıt

```
git config --global user.name "Ad Soyad"
git config --global user.email "senin@mailin.com"
```

B. Projeyi İndir

```
cd Desktop
git clone https://github.com/serhatkagans/tetz2026
cd tetz2026
git checkout -b ekip-12-guvenlik-xss
```

C. Göreviniz — Form & XSS Testleri

Kayıt formuna ve diğer alanlara zararlı içerik girmeyi deneyeceksin. Sistem bunu temizleyip temizlemediğini test edeceksin.

i Canlı siteyi aç: tetz2026.web.app → Kayıt formunu bul. Her alana aşağıdaki test metinlerini teker teker yaz ve gönder.

D. Test Senaryoları

Test için kullanacağın zararlı metinler (payload'lar):

```
<script>alert("XSS-1")</script>
<img src=x onerror=alert("XSS-2")>
"><script>alert("XSS-3")</script>
javascript:alert("XSS-4")
```

Beklenen: Alert kutusu AÇILMAMALI. Metin olduğu gibi görünmeli veya temizlenmeli.

T1 Ad Soyad alanına XSS payload yaz, gönder

Alert çıktı mı?

T2 Okul alanına XSS payload yaz

Alert çıktı mı?

T3 Tüm alanları boş bırak, gönder

Hata mesajı çıktı mı?

T4 Çok uzun metin yaz (1000+ karakter)

Sistem çöktü mü?

T5 Sınıf alanına sayı yerine harf yaz

Hata mesajı çıktı mı?

⬇️ Aşağıdaki metnin TAMAMINI kopyala, Cursor/Antigravity sohbetine yapıştır:

Sen TETZ2026 projesinin güvenlik test ekibisin (Ekip 12).
Form ve XSS testleri için docs/security-findings-xss.md dosyası oluştur.

```
# Form & XSS Güvenlik Test Raporu - Ekip 12
```

```
## Test Sonuçları
```

```
| Test | Alan | Payload | Alert Çıktı mı? | Risk |  
|-----|-----|-----|-----|-----|  
| T1 | Ad Soyad | <script>... | ? | ? |  
| T2 | Okul | <script>... | ? | ? |  
| T3 | Boş form | - | Hata var mı? | ? |  
| T4 | Uzun metin | 1000 karakter | ? | ? |  
| T5 | Sınıf alanı | harf | ? | ? |
```

```
## Bulgular
```

```
## Öneriler
```

Dosyayı oluştur, ben testleri yapıp dolduracağım.

**E. Çalışmanı Gönder**

```
git add .  
git commit -m "ekip-12: xss ve form guvenlik test raporu"  
git push origin ekip-12-guvenlik-xss
```

GitHub'da Pull Request aç, merge etme.

**Kontrol Et**

- ☐ Branch açtım: ekip-12-guvenlik-xss
- ☐ 5 XSS testini canlı sitede denedim
- ☐ docs/security-findings-xss.md oluştu ve doldurdum
- ☐ git push yapıldı, PR açıldı